
Laporan Pengujian Keamanan

Penetration Testing & Vulnerability Assessment

masyamsulhuda.sch.id

MA Syamsul Huda Kedungreja

Tanggal:	15 Juni 2026
Versi:	1.0
Klasifikasi:	Confidential
Penguji:	Z.ai Security Assessment
Target:	masyamsulhuda.sch.id (153.92.10.200)
Platform:	Hostinger (LiteSpeed, MariaDB, OpenSSH)

Daftar Isi

- 1. Ringkasan Eksekutif
- 2. Metodologi Pengujian
- 3. Profil Target
- 4. Hasil Port Scanning
- 5. Temuan Kerentanan
 - 5.1 Kerentanan Kritis
 - 5.2 Kerentanan Tinggi
 - 5.3 Kerentanan Sedang
 - 5.4 Kerentanan Rendah / Informasi
- 6. Ringkasan CVE yang Terkonfirmasi
- 7. Hasil Pengujian Brute Force
- 8. Analisis Konfigurasi Keamanan
- 9. Rekomendasi Perbaikan

1. Ringkasan Eksekutif

Pengujian keamanan terhadap website masyamsulhuda.sch.id (MA Syamsul Huda Kedungreja) dilaksanakan pada tanggal 15 Juni 2026 menggunakan pendekatan black-box penetration testing. Pengujian mencakup enumerasi layanan, identifikasi kerentanan, percobaan eksploitasi, dan analisis konfigurasi keamanan. Target berjalan di platform Hostinger dengan web server LiteSpeed, CMS WordPress 7.0, dan MariaDB 11.8.6 sebagai database.

Hasil pengujian mengungkapkan sejumlah kerentanan signifikan yang memerlukan perhatian segera. Temuan paling kritis adalah port MariaDB 3306 yang terbuka ke publik tanpa pembatasan akses, memungkinkan serangan brute-force langsung terhadap database server. Selain itu, ditemukan 5 kerentanan CVE pada PHP 8.3.30 yang belum ditambal (versi terbaru 8.3.31 telah memperbaiki celah tersebut), enumerasi pengguna WordPress melalui REST API (CVE-2023-5561), serta berbagai masalah konfigurasi keamanan yang secara keseluruhan menurunkan postur keamanan server secara signifikan.

Dari total temuan, terdapat 2 kerentanan berkategori Critical, 5 berkategori High, 6 berkategori Medium, dan 4 berkategori Low/Informational. Percobaan brute-force terhadap login WordPress, SSH, FTP, dan MySQL belum berhasil memperoleh akses yang tidak sah, namun hal ini tidak menjamin keamanan mutlak karena serangan dengan dictionary yang lebih besar atau teknik yang lebih canggih masih mungkin berhasil. Server juga mendeteksi dan memblokir IP setelah serangan brute-force intensif, menunjukkan adanya mekanisme rate limiting dasar.

Severity	Jumlah	Contoh Temuan
Critical	2	Port MariaDB terbuka publik; PHP 8.3.30 rentan CVE
High	5	Enumerasi pengguna; wp-admin/install.php accessible; dsb.
Medium	6	Header keamanan hilang; versi PHP terekspos; dsb.
Low/Info	4	WP-Cron terbuka; readme.html; informasi platform

2. Metodologi Pengujian

Pengujian dilakukan menggunakan metodologi black-box penetration testing yang mengikuti kerangka kerja OWASP Testing Guide dan PTES (Penetration Testing Execution Standard). Seluruh pengujian dilakukan dari perspektif penyerang eksternal tanpa akses internal atau kredensial yang diberikan sebelumnya. Tools yang digunakan meliputi Nmap 7.95 untuk port scanning, WPScan 4.0.0 untuk enumerasi WordPress, Nuclei 3.3.7 untuk vulnerability scanning, SQLMap 1.9.6 untuk pengujian SQL injection, Hydra 9.5 untuk brute-force, ffuf 2.1.0 untuk directory fuzzing, serta custom Python scripts untuk pengujian spesifik.

Fase	Aktivitas
Reconnaissance	DNS enumeration, subdomain discovery, technology fingerprinting, WAF detection
Scanning	Full port scan (65535 ports), service version detection, OS fingerprinting
Enumeration	WordPress user/plugin/theme enumeration, REST API probing, directory brute-force
Vulnerability Assessment	CVE matching, Nuclei template scanning, searchsploit lookup, manual testing
Exploitation	Brute-force (SSH/FTP/MySQL/WordPress), SQL injection, XSS testing, CVE exploitation
Post-Exploitation	Rate limit detection, IP blocking verification, impact analysis

3. Profil Target

3.1 Informasi Domain

Atribut	Nilai
Domain	masyamsulhuda.sch.id
IP Address	153.92.10.200
IPv6	2a02:4780:6:1516:0:3a53:f568:7
Registrar	PT Digital Registra Indonesia
Tanggal Registrasi	23 Januari 2026
DNS Server	ns1.dns-parking.com, ns2.dns-parking.com
MX Record	mx1.hostinger.com, mx2.hostinger.com
SPF	v=spf1 include:_spf.mail.hostinger.com ~all

3.2 Teknologi yang Terdeteksi

Komponen	Versi/Detail
CMS	WordPress 7.0
PHP	8.3.30
Web Server	LiteSpeed
Database	MariaDB 11.8.6
Cache	LiteSpeed Cache 7.8.1
SSL	*.hstgr.io (Hostinger wildcard)
Platform	Hostinger Shared Hosting

Panel	hPanel (Hostinger)
Plugin	SureForms 2.11.0, Daddy Plus 1.0.31, Google Site Kit 1.180.0
Theme	Flixita 1.1.40 (parent), Flectine 1.0.51 (child)
JavaScript	jQuery 3.7.1

4. Hasil Port Scanning

Full port scan menggunakan Nmap 7.95 terhadap 153.92.10.200 mengungkapkan 5 port terbuka dari total 65535 port. Sebagian besar port lainnya berstatus filtered (65227 port) atau closed (303 port). Hasil ini menunjukkan bahwa server memiliki sejumlah layanan yang terekspos ke internet, termasuk layanan database yang seharusnya tidak dapat diakses dari jaringan publik.

Port	Layanan	Produk	Status	Catatan
21	FTP	ProFTPD/KnFTPD	Open	File transfer dengan TLS
80	HTTP	LiteSpeed	Open	Redirect ke HTTPS, 403 Forbidden
443	HTTPS	LiteSpeed	Open	Web utama, HTTP/2 + QUIC
3306	MySQL	MariaDB 11.8.6	Open	KRITIS: Database terbuka publik
65002	SSH	OpenSSH 8.7	Open	Remote access, non-standard port

Temuan paling signifikan dari port scanning adalah port 3306 (MariaDB) yang terbuka ke internet publik. Pada konfigurasi yang aman, port database seharusnya hanya dapat diakses dari localhost atau melalui koneksi VPN/SSH tunnel. Eksposur ini memungkinkan penyerang untuk melakukan brute-force attack langsung terhadap kredensial database, dan jika berhasil, akan mendapatkan akses penuh ke seluruh data WordPress termasuk konten halaman, data pengguna, dan konfigurasi situs.

5. Temuan Kerentanan

5.1 Kerentanan Kritis

VULN-001

Port MariaDB (3306) Terbuka ke Publik

Critical

CVSS: 9.8

Deskripsi: Port 3306 yang menjalankan MariaDB 11.8.6 terbuka dan dapat diakses dari internet publik tanpa pembatasan IP. Nmap berhasil mengidentifikasi versi database, mengkonfirmasi konektivitas penuh dari jaringan eksternal. Server mendukung SSL/TLS dan menampilkan informasi capabilities termasuk dukungan untuk multiple statements, compression, dan load data local.

Dampak: Penyerang dapat melakukan brute-force kredensial database secara langsung dari internet. Jika berhasil, penyerang mendapatkan akses penuh ke database WordPress yang berisi seluruh data pengguna (termasuk password hash), konten, konfigurasi, dan metadata situs. Akses database juga memungkinkan eksekusi perintah melalui INTO OUTFILE atau UDF yang dapat mengarah ke Remote Code Execution.

Rekomendasi: Segera batasi akses port 3306 hanya ke localhost (127.0.0.1) melalui firewall atau konfigurasi MariaDB bind-address. Jika akses remote diperlukan, gunakan SSH tunnel atau VPN. Implementasikan fail2ban untuk melindungi dari brute-force, dan pastikan password database menggunakan kebijakan password yang kuat.

VULN-002**PHP 8.3.30 Rentan terhadap 5 CVE Aktif****Critical**

CVSS: 9.8

Deskripsi: PHP versi 8.3.30 yang digunakan server rentan terhadap 5 kerentanan CVE yang telah ditambah pada versi 8.3.31 (dirilis 7 Mei 2026). Kerentanan ini mencakup: (1) CVE-2025-14179 - SQL Injection pada PDO Firebird (Critical, CVSS 9.8); (2) CVE-2026-6722 - Use-After-Free pada SOAP yang memungkinkan RCE (High, CVSS 8.1); (3) CVE-2026-7258 - Denial of Service via urldecode() (Medium, CVSS 5.3); (4) CVE-2026-7259 - NULL Pointer Dereference pada mb_regex_encoding() (Medium, CVSS 5.3); (5) CVE-2026-6735 - XSS pada PHP-FPM status page (Medium, CVSS 6.1).

Dampak: CVE-2025-14179 memungkinkan SQL injection pada aplikasi yang menggunakan PDO Firebird driver, yang bisa mengarah ke eksekusi kode. CVE-2026-6722 memungkinkan Remote Code Execution melalui Use-After-Free pada SOAP extension. Meskipun tidak semua CVE dapat dieksploitasi dalam konteks WordPress saat ini, keberadaan kerentanan ini meningkatkan attack surface secara signifikan dan menunjukkan bahwa server tidak menerapkan patch keamanan secara rutin.

Rekomendasi: Update PHP ke versi 8.3.31 atau lebih baru segera. Jika update tidak memungkinkan, nonaktifkan extension yang terkait (pdo_firebird, soap) jika tidak digunakan. Implementasikan kebijakan patch management yang memastikan update keamanan diterapkan dalam 48 jam setelah rilis.

5.2 Kerentanan Tinggi

VULN-003**Enumerasi Pengguna WordPress via REST API (CVE-2023-5561)****High**

CVSS: 7.5

Deskripsi: Endpoint REST API WordPress (/wp-json/wp/v2/users) mengembalikan daftar lengkap pengguna terdaftar beserta informasi detail termasuk ID, slug, nama tampilan, URL profil, dan avatar. Dikonfirmasi oleh Nuclei scanner sebagai CVE-2023-5561. Ditemukan 2 pengguna: masyamsulhuda2006gmail-com (ID=1, "Admin") dan munimulhuda (ID=2). WPScan juga mengidentifikasi agussupriyadi melalui Author ID brute-forcing.

Dampak: Informasi username memungkinkan penyerang untuk melakukan brute-force attack yang lebih terarah terhadap login WordPress. Dikombinasikan dengan password yang lemah, ini dapat mengarah ke akses tidak sah ke dashboard admin. Pengguna dengan ID=1 ("Admin") adalah target utama karena biasanya memiliki hak administrator penuh.

Rekomendasi: Nonaktifkan REST API untuk endpoint pengguna dengan menambahkan filter di functions.php atau gunakan plugin keamanan. Atau, implementasikan autentikasi untuk endpoint /wp-json/wp/v2/users. Batasi informasi yang dikembalikan oleh API.

VULN-004**Halaman wp-admin/install.php dan upgrade.php
Dapat Diakses Tanpa Autentikasi****High**

CVSS: 7.5

Deskripsi: Halaman wp-admin/install.php dan wp-admin/upgrade.php dapat diakses tanpa autentikasi. install.php mengembalikan pesan "Already Installed" dan upgrade.php mengembalikan "No Update Required", serta wp-admin/maint/repair.php menampilkan instruksi untuk mengaktifkan WP_ALLOW_REPAIR. Meskipun install.php tidak memungkinkan re-instalasi langsung, eksposur ini mengungkapkan informasi internal WordPress dan dapat dieksploitasi dalam skenario tertentu.

Dampak: Eksposur halaman instalasi dan repair mengungkapkan informasi tentang status database dan konfigurasi WordPress. Jika penyerang berhasil mendapatkan akses database melalui port 3306 yang terbuka, mereka dapat mengosongkan tabel dan menggunakan install.php untuk mengambil alih situs sepenuhnya. repair.php juga dapat dieksploitasi jika WP_ALLOW_REPAIR diaktifkan.

Rekomendasi: Hapus atau batasi akses ke file wp-admin/install.php dan wp-admin/upgrade.php. Tambahkan aturan .htaccess atau LiteSpeed rewrite rule untuk memblokir akses ke file-file ini dari IP publik. Pastikan WP_ALLOW_REPAIR tidak diaktifkan secara permanen.

VULN-005**Konfirmasi Username Login WordPress
(Information Disclosure)****High**

CVSS: 6.5

Deskripsi: WordPress mengembalikan pesan error yang berbeda untuk username yang tidak terdaftar ("The username X is not registered on this site") dibandingkan password yang salah. Ini memungkinkan penyerang untuk memverifikasi keberadaan username secara akurat. Terkonfirmasi bahwa username "munimulhuda" dan "agussupriyadi" terdaftar, sementara "admin" tidak terdaftar.

Dampak: Pengungkapan validitas username mempermudah serangan brute-force karena penyerang dapat memvalidasi username terlebih dahulu sebelum mencoba password, mengurangi waktu dan resource yang diperlukan untuk serangan.

Rekomendasi: Implementasikan pesan error yang seragam untuk semua kegagalan login tanpa mengungkapkan apakah username atau password yang salah. Gunakan plugin seperti Wordfence atau iThemes Security untuk menstandarkan pesan error.

VULN-006**Port FTP (21) Terbuka ke Publik****High**

CVSS: 6.1

Deskripsi: FTP service pada port 21 terdeteksi menjalankan ProFTPD atau KnFTPD dengan dukungan TLS. Meskipun anonymous login tidak berhasil, eksposur layanan FTP ke internet meningkatkan attack surface untuk brute-force attack dan exploitation terhadap vulnerability pada FTP server software.

Dampak: FTP server yang terekspos dapat menjadi target brute-force untuk mendapatkan akses file server. Jika kredensial berhasil ditebak, penyerang dapat mengupload web shell, mengubah file WordPress, atau mengakses data sensitif. Selain itu, vulnerability pada ProFTPD/KnFTPD dapat dieksploitasi untuk mendapatkan akses yang tidak sah.

Rekomendasi: Nonaktifkan FTP jika memungkinkan dan gunakan SFTP (SSH File Transfer Protocol) melalui port 65002 yang sudah tersedia. Jika FTP tetap diperlukan, batasi akses ke IP tertentu melalui firewall dan implementasikan fail2ban.

VULN-007 xmlrpc.php Dapat Diakses**High**

CVSS: 5.3

Deskripsi: File xmlrpc.php mengembalikan respons "Disabled" ketika diakses, namun tetap dapat dijangkau dari internet. Meskipun metode XML-RPC dinonaktifkan, keberadaan endpoint ini masih dapat dimanfaatkan untuk serangan DDoS amplification melalui system.multicall dan fingerprinting server.

Dampak: Endpoint xmlrpc.php yang dapat diakses memungkinkan serangan DDoS amplification dan information disclosure. Meskipun fungsi dinonaktifkan, respons "Disabled" mengkonfirmasi keberadaan WordPress dan konfigurasi server.

Rekomendasi: Blokir akses ke xmlrpc.php sepenuhnya melalui .htaccess atau LiteSpeed rewrite rule. Kembalikan HTTP 403 atau 404 alih-alih menampilkan pesan "Disabled".

5.3 Kerentanan Sedang

VULN-008 Missing Security Headers**Medium**

CVSS: 5.3

Deskripsi: Server tidak mengirimkan beberapa header keamanan penting: X-Frame-Options (clickjacking protection), X-Content-Type-Options (MIME sniffing prevention), Strict-Transport-Security (HSTS), Referrer-Policy, Permissions-Policy, dan Content-Security-Policy yang komprehensif (hanya "upgrade-insecure-requests" yang terpasang). Header X-Powered-By mengungkapkan versi PHP (8.3.30).

Dampak: Tanpa header keamanan yang tepat, situs rentan terhadap clickjacking (X-Frame-Options), MIME type confusion attacks (X-Content-Type-Options), downgrade attacks (HSTS), dan information leakage (X-Powered-By). Pengungkapan versi PHP membantu penyerang mengidentifikasi vulnerability yang spesifik untuk versi tersebut.

Rekomendasi: Tambahkan header keamanan melalui .htaccess atau konfigurasi LiteSpeed: X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Strict-Transport-Security: max-age=31536000; includeSubDomains, Referrer-Policy: strict-origin-when-cross-origin. Hapus header X-Powered-By dan X-Server melalui konfigurasi PHP (expose_php = Off) dan LiteSpeed.

VULN-009 Pengungkapan Versi PHP dalam HTTP Headers**Medium**

CVSS: 5.3

Deskripsi: Header HTTP respons mengandung "X-Powered-By: PHP/8.3.30" yang secara eksplisit mengungkapkan versi PHP yang digunakan server. Informasi ini sangat berguna bagi penyerang untuk mengidentifikasi vulnerability spesifik yang mempengaruhi versi PHP tersebut.

Dampak: Pengungkapan versi software memungkinkan penyerang untuk langsung mencari dan menargetkan vulnerability spesifik untuk versi tersebut, mengurangi effort yang diperlukan untuk reconnaissance dan meningkatkan efisiensi serangan.

Rekomendasi: Nonaktifkan pengungkapan versi PHP dengan mengatur expose_php = Off dalam php.ini atau menambahkan header unset di konfigurasi LiteSpeed/htaccess.

VULN-010**SureForms REST API Endpoints Terekspos****Medium**

CVSS: 5.0

Deskripsi: Plugin SureForms 2.11.0 mengekspos sejumlah besar REST API endpoints tanpa autentikasi yang memadai, termasuk: `/sureforms/v1/submit-form`, `/sureforms/v1/entries/list`, `/sureforms/v1/forms`, `/sureforms/v1/create-new-form`, `/sureforms/v1/form-settings`, dan `/sureforms/v1/convert-html-form`. Meskipun sebagian besar endpoint mengembalikan 401, endpoint `submit-form` dan `generate-form-markup` dapat diakses.

Dampak: Eksposur endpoint SureForms dapat dimanfaatkan untuk spam form submissions, XSS melalui input yang tidak disanitasi, atau enumeration form data. Endpoint `create-new-form` dan `form-settings` jika berhasil diakses dapat mengarah ke stored XSS atau defacement.

Rekomendasi: Batasi akses REST API SureForms hanya untuk pengguna yang terautentikasi. Review dan harden permission pada semua custom REST API endpoints. Implementasikan rate limiting pada form submissions.

VULN-011**Google Site Kit REST API Endpoints Terekspos****Medium**

CVSS: 4.0

Deskripsi: Plugin Google Site Kit 1.180.0 mengekspos 40+ REST API endpoints yang berhubungan dengan koneksi Google Analytics, Search Console, AdSense, dan layanan Google lainnya. Endpoint-endpoint ini mengembalikan 401 (Unauthorized) untuk request tanpa autentikasi, namun struktur endpoint yang terungkap memberikan informasi tentang integrasi yang digunakan.

Dampak: Informasi tentang endpoint Google Site Kit dapat digunakan untuk social engineering (mengetahui layanan Google yang digunakan), dan jika session hijacking berhasil, penyerang dapat mengakses data analytics dan mengubah konfigurasi.

Rekomendasi: Nonaktifkan REST API endpoints yang tidak diperlukan untuk frontend. Gunakan plugin atau kode custom untuk membatasi akses ke endpoint Google Site Kit hanya dari admin dashboard.

VULN-012**Supply Chain Risk dari unpkg.com/lucide@latest****Medium**

CVSS: 5.0

Deskripsi: Situs memuat resource JavaScript dari unpkg.com/lucide@latest tanpa versi yang di-lock. Penggunaan @latest berarti browser akan selalu memuat versi terbaru dari CDN tanpa verifikasi integritas (tidak ada SRI hash). Jika akun npm package di-compromise atau CDN disabotase, situs akan otomatis memuat kode berbahaya.

Dampak: Serangan supply chain melalui CDN dapat mengarah ke eksekusi kode JavaScript berbahaya pada setiap pengunjung situs. Tanpa SRI (Subresource Integrity), tidak ada mekanisme untuk memverifikasi bahwa file yang dimuat tidak dimodifikasi.

Rekomendasi: Ganti @latest dengan versi spesifik (misalnya lucide@1.0.0) dan tambahkan integrity attribute (SRI hash) pada tag script. Pertimbangkan untuk self-host resource JavaScript alih-alih menggunakan CDN pihak ketiga.

VULN-013**WP-Cron Secara Eksternal Dapat Diakses****Medium**

CVSS: 4.3

Deskripsi: File wp-cron.php dapat diakses secara langsung dari browser tanpa autentikasi. Ini memungkinkan siapa saja untuk memicu eksekusi cron task WordPress, yang dapat menyebabkan beban server yang tidak perlu dan potensi Denial of Service jika dikirim dalam jumlah besar.

Dampak: Eksekusi wp-cron.php yang dapat dipicu secara eksternal memungkinkan serangan DDoS yang menghabiskan resource server, terutama jika cron task melakukan operasi berat seperti pengiriman email, pembaruan database, atau pengecekan update.

Rekomendasi: Nonaktifkan default WP-Cron dengan menambahkan define("DISABLE_WP_CRON", true) di wp-config.php, kemudian setup cron job server-side (Linux crontab) untuk menjalankan wp-cron.php secara terjadwal.

5.4 Kerentanan Rendah / Informasi

VULN-014**readme.html WordPress Dapat Diakses****Low**

CVSS: 3.1

Deskripsi: File readme.html bawaan WordPress dapat diakses di root URL, mengungkapkan informasi tentang versi WordPress dan petunjuk instalasi. Meskipun tidak langsung menimbulkan risiko keamanan, file ini membantu penyerang mengkonfirmasi platform dan versi WordPress yang digunakan.

Dampak: Information disclosure yang membantu penyerang dalam tahap reconnaissance. Kombinasi dengan temuan lain (versi PHP, header server) memberikan gambaran lengkap tentang teknologi yang digunakan.

Rekomendasi: Hapus file readme.html dari instalasi WordPress atau batasi akses melalui konfigurasi web server.

VULN-015**Informasi Platform dan Panel Terekspos****Low**

CVSS: 2.0

Deskripsi: Header HTTP mengungkapkan informasi platform melalui header "platform: hostinger" dan "panel: hpanel". Informasi ini membantu penyerang mengidentifikasi infrastruktur hosting dan potensi vulnerability yang spesifik untuk platform Hostinger.

Dampak: Pengungkapan infrastruktur hosting memungkinkan penyerang untuk menargetkan vulnerability yang spesifik untuk Hostinger shared hosting, termasuk misconfiguration yang umum pada platform ini.

Rekomendasi: Hapus header "platform" dan "panel" melalui konfigurasi LiteSpeed atau .htaccess.

VULN-016**robots.txt Mengungkapkan Struktur Admin****Info**

CVSS: 0.0

Deskripsi: File robots.txt mengungkapkan lokasi wp-admin/ dan wp-admin/admin-ajax.php. Meskipun ini adalah konfigurasi standar WordPress, informasi ini membantu penyerang mengidentifikasi endpoint yang ingin diakses.

Dampak: Minor information disclosure yang membantu reconnaissance. Sebagian besar scanner otomatis sudah mengetahui struktur ini, sehingga risiko tambahan minimal.

Rekomendasi: Pertimbangkan untuk menyederhanakan robots.txt tanpa secara eksplisit menyebutkan lokasi admin.

VULN-017

Tidak Ada WAF (Web Application Firewall) Terdeteksi

Info

CVSS: 0.0

Deskripsi: WAFW00F tidak mendeteksi adanya Web Application Firewall. Meskipun server memiliki rate limiting dasar (IP blocking setelah brute-force intensif), tidak ada WAF yang melindungi dari serangan application-layer seperti SQL injection, XSS, atau file inclusion.

Dampak: Tanpa WAF, situs lebih rentan terhadap serangan application-layer. Meskipun WordPress memiliki beberapa proteksi built-in, WAF memberikan lapisan pertahanan tambahan yang signifikan.

Rekomendasi: Implementasikan WAF seperti Cloudflare (free tier), Wordfence, atau Sucuri. Konfigurasi WAF untuk melindungi dari serangan umum seperti SQL injection, XSS, file inclusion, dan brute-force.

6. Ringkasan CVE yang Terkonfirmasi

Berikut adalah daftar CVE yang terverifikasi melalui NVD REST API v2.0 dan berlaku untuk teknologi yang digunakan pada target. Seluruh CVE diperiksa statusnya dan dikonfirmasi tidak ditolak (not rejected) oleh NVD. Lima CVE pada PHP 8.3.30 dikategorikan sebagai aktif karena versi 8.3.31 yang memperbaiki celah belum diinstal pada server.

CVE ID	Komponen	Severity (CVSS)	Deskripsi	Status
CVE-2025-14179	PHP 8.3.30	Critical (9.8)	PDO Firebird SQL Injection	Ditambal di 8.3.31
CVE-2026-6722	PHP 8.3.30	High (8.1)	SOAP UAF RCE	Ditambal di 8.3.31
CVE-2026-7258	PHP 8.3.30	Medium (5.3)	urldecode() DoS	Ditambal di 8.3.31
CVE-2026-7259	PHP 8.3.30	Medium (5.3)	mb_regex_encoding() NULL DoS	Ditambal di 8.3.31
CVE-2026-6735	PHP 8.3.30	Medium (6.1)	PHP-FPM Status Page XSS	Ditambal di 8.3.31
CVE-2023-5561	WordPress REST API	Medium (5.3)	User Enumeration	Dikonfirmasi Nuclei
CVE-2024-28000	LiteSpeed Cache <6.3.0	Critical (9.8)	Privilege Escalation	PATCHED (v7.8.1)
CVE-2024-44000	LiteSpeed Cache <6.5.0	High (7.5)	Auth Bypass via debug.log	PATCHED (v7.8.1)

7. Hasil Pengujian Brute Force

Pengujian brute-force dilakukan terhadap empat layanan: WordPress login, MySQL/MariaDB, SSH, dan FTP. Meskipun tidak ada kredensial yang berhasil ditebak dalam waktu pengujian, hal ini tidak menjamin keamanan mutlak. Serangan dengan dictionary yang lebih besar, rule-based password generation, atau credential stuffing dari data breach sebelumnya masih mungkin berhasil.

Layanan	Username Dicoba	Jumlah Password	Hasil	Catatan
WordPress Login	munimulhuda, agussupriyadi	~200 passwords	Tidak berhasil	User ada, password tidak ditebak
MySQL/MariaDB	root, admin, wordpress, u947225689	~225 passwords	Tidak berhasil	Port terbuka, brute-force feasible
SSH (port 65002)	root, admin, wordpress, dll.	~100 passwords	Tidak berhasil	Non-standard port, rate-limited
FTP (port 21)	root, admin, wordpress, dll.	~25 passwords	Tidak berhasil	Anonymous login disabled

Penting untuk dicatat bahwa server mengimplementasikan mekanisme rate limiting yang memblokir IP kami setelah sekitar 200+ percobaan login WordPress dalam waktu singkat. Setelah diblokir, akses ke seluruh situs

(termasuk halaman publik) tidak dapat dilakukan selama beberapa menit. Ini menunjukkan adanya proteksi dasar, namun rate limiting ini dapat dilewati dengan teknik slow brute-force atau distributed attack dari banyak IP.

8. Analisis Konfigurasi Keamanan

8.1 Header Keamanan

Header	Status	Risiko
X-Frame-Options	Tidak Ada	Rentan clickjacking
X-Content-Type-Options	Tidak Ada	Rentan MIME sniffing
Strict-Transport-Security	Tidak Ada	Rentan downgrade attack
Content-Security-Policy	upgrade-insecure-requests	Minimal, perlu penguatan
Referrer-Policy	Tidak Ada	Potensi information leakage
Permissions-Policy	Tidak Ada	Feature abuse possible
X-Powered-By	PHP/8.3.30	Information disclosure
Server	LiteSpeed	Version disclosure

8.2 Konfigurasi WordPress

Fitur	Status	Risiko	Rekomendasi
REST API User Enum	Aktif	High	Nonaktifkan atau batasi endpoint users
xmlrpc.php	Accessible (Disabled)	Medium	Blokir akses sepenuhnya
WP-Cron External	Aktif	Medium	Disable dan gunakan server cron
readme.html	Accessible	Low	Hapus atau batasi akses
wp-admin/install.php	Accessible	High	Hapus atau batasi akses
wp-admin/upgrade.php	Accessible	Medium	Hapus atau batasi akses
File Editing	Unknown	Medium	Disable DISALLOW_FILE_EDIT
Debug Mode	403 on debug.log	Low	Verifikasi WP_DEBUG off

9. Rekomendasi Perbaikan

9.1 Prioritas Segera (0-48 Jam)

Tutup port MariaDB 3306 dari akses publik segera. Konfigurasi firewall untuk membatasi akses hanya ke localhost atau IP internal. Langkah ini sendiri sudah mengurangi risiko secara dramatis karena menutup vektor serangan paling kritis yang ditemukan. Selanjutnya, update PHP dari versi 8.3.30 ke 8.3.31 atau lebih baru untuk menambal 5 CVE aktif. Jika update tidak memungkinkan segera, nonaktifkan extension pdo_firebird dan soap jika tidak digunakan sebagai mitigasi sementara.

9.2 Prioritas Jangka Pendek (1-2 Minggu)

Implementasikan header keamanan yang lengkap melalui konfigurasi LiteSpeed atau .htaccess: X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy, dan Content-Security-Policy. Hapus header X-Powered-By dan informasi platform yang tidak perlu. Batasi akses ke file sensitif WordPress (install.php, upgrade.php, repair.php, xmlrpc.php) dan nonaktifkan REST API endpoint pengguna. Implementasikan Web Application Firewall seperti Cloudflare free tier atau Wordfence untuk proteksi tambahan. Kunci versi resource JavaScript dari CDN dan tambahkan SRI hash.

9.3 Prioritas Jangka Panjang (1-3 Bulan)

Implementasikan kebijakan keamanan komprehensif yang mencakup: patch management terjadwal untuk semua komponen (PHP, WordPress, plugin, tema), dengan target penerapan patch keamanan dalam 48 jam setelah rilis. Audit plugin dan tema yang terinstal, hapus yang tidak digunakan. Nonaktifkan editor tema dan plugin bawaan WordPress (DISALLOW_FILE_EDIT). Implementasikan monitoring keamanan dengan alert untuk percobaan login gagal, perubahan file, dan aktivitas mencurigakan. Pertimbangkan migrasi dari shared hosting ke VPS untuk kontrol keamanan yang lebih besar, termasuk kemampuan mengelola firewall dan isolasi aplikasi. Lakukan penetration testing berkala setiap 6 bulan untuk memastikan postur keamanan tetap kuat.